Knightsec

University of Central Florida
(Team 11)

White Team Document

Table of Contents

Introduction **3**

Service Summary Table **4**

Network Architecture Diagram **5**

Overall Plan **6**

Provided Services Information **6**

- Active Directory 6
- Ticketing Machine 7
- Management Backend 9
- Admin User Interface 10
- Public Website (WWW) 13

Custom Services and Boxes **15**

- Backups 16
- Router 16

Introduction

The following white team documentation will summarize team 11's, Knightsec's efforts to maintain and protect the environment given to us.

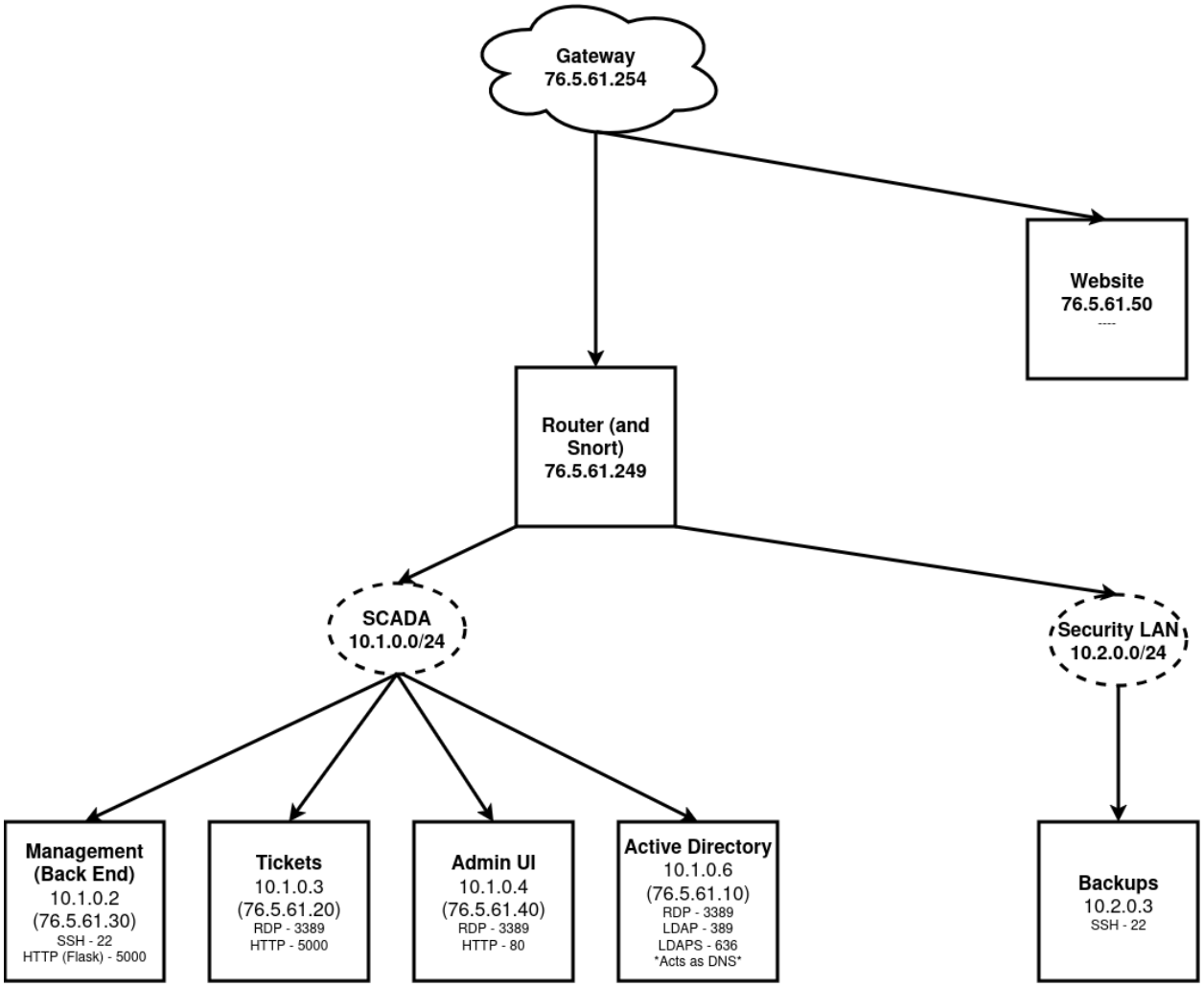
This documentation is separated into a few main parts which include a table summary of our required service information, a network diagram complete with IP addresses and ports, a change log and summary of the machines and services provided to us, documentation of any new services and boxes we have created to better secure our environment.

After reading through this document you will have a complete understanding of our plan and the steps we have taken to set up and secure this environment.

Service Summary Table

Domain Name	IP Address Public & Internal	Ports	Services
www.ad.team11.isucdc.com	76.5.61.10 10.1.0.6	389, 636, 3389	AD LDAP, LDAPS, RDP
www.tickets.team11.isucdc.com	76.5.61.20	3389, 5000	RDP, HTTP
www.mgmt.team11.isucdc.com	76.5.61.30	22, 5000	SSH, HTTP
www.admin.team11.isucdc.com	76.5.61.40	80, 3389	HTTP, RDP
www.team11.isucdc.com	76.5.61.50 N/A	22, 80	Admin SSH, HTTP

Network Architecture Diagram



Overall Plan

Due to the sensitive nature of this environment and the vast transportation network that it controls, team 11 is focusing on going through and securing each box and keeping the services that are running to a minimum to reduce attack surface. There are exceptions to this rule, such as Snort on the newly created pfsense box. By focusing our efforts of ridding provided boxes of preplants and further securing as well as securing newly created boxes to assist in securing the overall environment, we will be able to focus on what's important when the environment is actually being attacked.

While the boxes and services are under attack our first priority will be to make sure our services don't get interrupted and ensure as many points as possible from service uptime. From there our second priority will be any possible business needs. Everything boils down to ensuring our points are secured via keeping services up, keeping customers data safe, and satisfying any business needs. Priorities at different times may change if there are points on the line.

Provided Services Information

Within this part of the document, each main section is a different box that was provided to team 11. Within each main section we will discuss the operating system the box is running, what services are running on the box, the overall purpose of the box, our plan and methodology to set up and secure the box, and finally what changes we made to set up and secure said box.

Active Directory

The active directory machine runs Windows Server 2016 and currently has the public ip 76.5.61.10 and an internal ip of 10.1.0.6. It acts as a domain controller and a DNS server for the entirety of the network. This means it manages user authentication across all the machines and website logins. This box also provides the certificates used by the ticketing machine. The services on this box are LDAP on port 389, LDAPS on port 636, RDP on port 3389, along with general active directory and DNS services.

Plan and Notes

As the active directory box provides many essential services for the basic operation of the environment we put a lot of emphasis on keeping this box secure. As such we scoured the box for any indicators of compromise and ridded the box of possible malicious and insecure options, programs, services, etc.

Almost every box depends on this box in one way or another as it is required for services such as user authentication and DNS services. A notable box that depends on this one is the ticketing machine as that box must be able to request certificates from the active directory box.

Change Log

- This Active Directory machine has been secured through a hardened firewall, only allowing inbound and outbound connections through port 3389, 636, 53, and 88.

- There are also firewall connections for each other IP in the network. Logging has been included so all traffic is recorded.

- DNS has been fully backed up in case we need to revert it to a working state.

- A domain-wide password policy and lockout policy has been set. The default passwords for each domain user has been changed to fit the spreadsheet and the admin password has been changed to be more secure.

- The user list has been checked over to make sure that each user is in the correct group.

- Backups on this machine are sent to our backup box so that if we ever get attacked we have a point to return that is not very long in the past.

Ticketing Machine

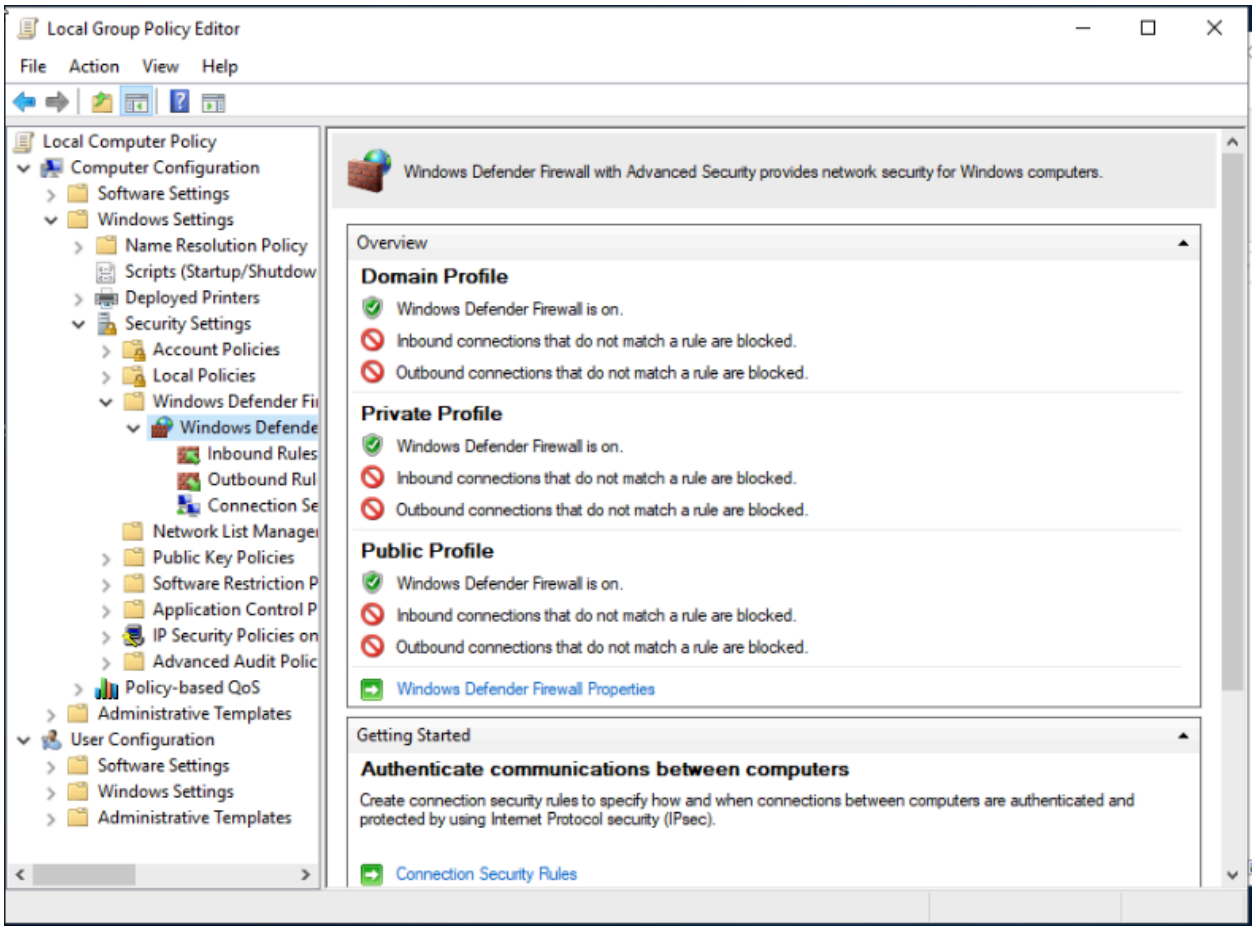
The ticketing machine runs Window Server 2019 and currently has an public ip of 76.5.61.20. This server was a provided box that issues and validates tickets for bus and train services and represents the backend system for physical ticket readers at stations or on vehicles. The services hosted on this box are HTTP on port 5000, and RDP on port 3389.

Plan and Notes

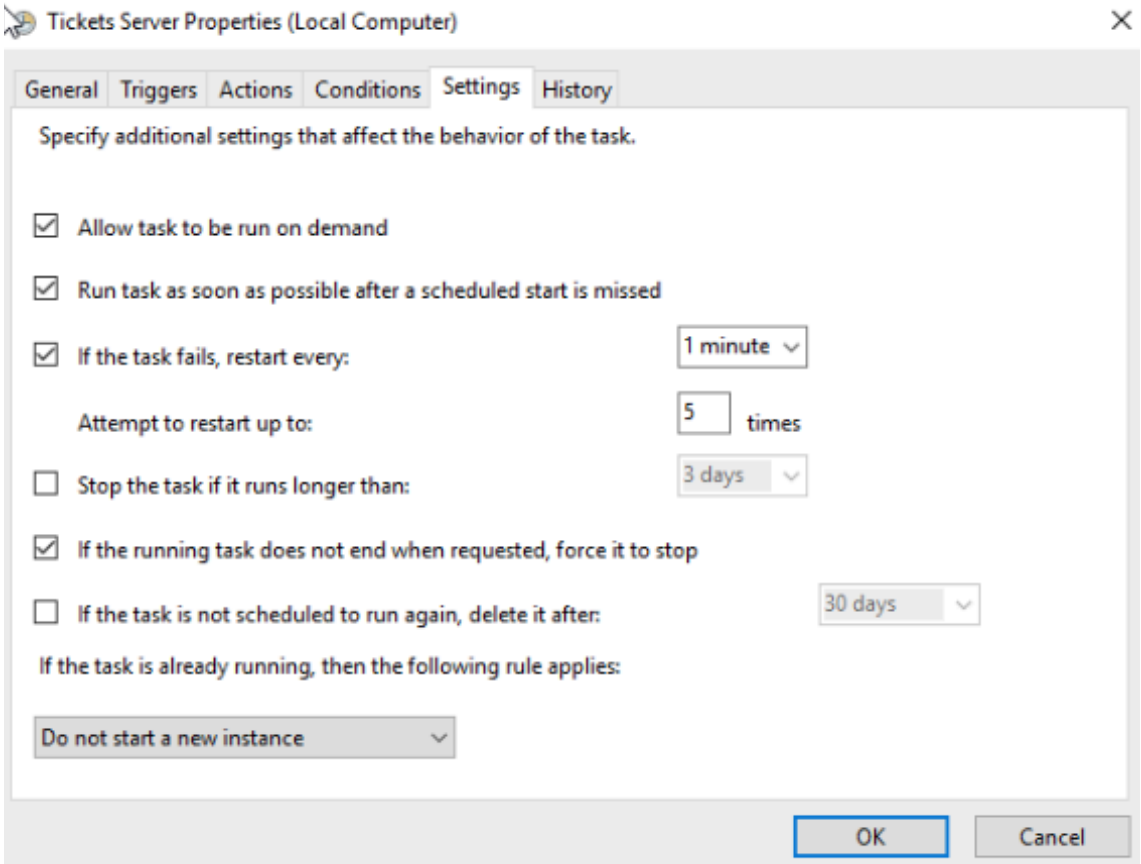
The ticketing machine provides many essential services that employees use in order to serve basic operations to the customers. The HTTP server on port 5000 serves as an backend API for a couple of different services including many physical ticket readers at stations or on vehicles. Due to this nature this service must be available from the competition network. In addition, this service must be available to the management backend.

Change Log

- The host firewall has been configured to only allow inbound traffic on port 3389 and 5000, all traffic to and from the Domain Controller, and outbound traffic for Firefox and Internet Explorer.



- Firewall logging has been enabled for all network traffic. The ticketing service program was incorrectly configured to shut off after 3 days, this has been fixed and also configured to restart automatically if shut off.



- Enabled auditing of logon successes and failures and access to critical system components. The password of the built-in administrator account has been changed to a secure password.

Management Backend

This box runs AlmaLinux 8.4 and has an public ip of 76.5.61.30. This box is the main transit management backend to both user interfaces on the admin UI box and the public facing WWW website. This box handles user authentication, ticket payments, and fleet and route management for the city's transportation. The services hosted on this box are SSH on port 22, and HTTP on port 5000.

Plan and Notes

Just like the active directory box, this box's services are depended on by many others. As such we took extra time and care securing this box and ridding it of any malicious options, services, programs, etc. If this box goes down so will many essential services for the customers.

The HTTP service on port 5000 on this box acts as an backend API for the various websites hosted on the environment. This notably includes the admin UI and the public website.

Change Log

- The management backend has had default user credentials rotated, as well as host based firewalls configured. It only allows connections from ports 22, 5000, 389, and 636. All connections are accepted from the AD box. PAM was also reinstalled in the case of a modified PAM.

- Management also had processes audited, and connections checked for malicious connections. We audited the source code of the management application and found multiple misconfigurations. We have remediated them.

- Listed below is evidence of the vulnerabilities discovered on the management application:
    - Weak Secret Used for Session Token Signature
        - The secret key was modified to be a stronger and more secure secret key.
    - Flask Misconfiguration Leading to RCE
        - evalex flag set to False.
    - Disabled high privileged group addition when registering a new user.

Admin User Interface

This box runs WIndows Server 2022 and has a public ip of 76.5.61.40. This machine hosts the city’s admin portal/UI for viewing the status of the city’s transportation system and managing its fleet of vehicles. The services hosted on this box are HTTP on port 80, and RDP on port 3389.

Plan and Notes

The Admin UI box provides many services that are required to manage the transportation network throughout the city. Since there are a small number of users that are required to access this website we constricted access intensively while making sure that it still operates as intended.

While the services on this box aren't dependencies themselves, the services on this box depend on a bunch of services. If any one of the dependencies goes down, this box will also go down.

Change Log

- Set “evalex = True” to “false”

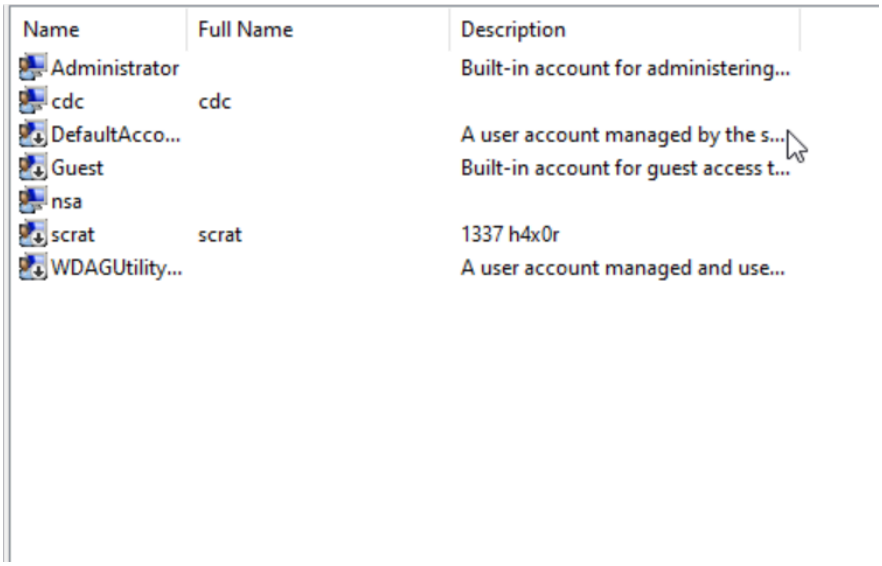
```
import os

from flask import Flask
from werkzeug.debug import DebuggedApplication

from app import routes
from app.config import Config


def create_app():
    app = Flask(__name__)

    # Load configuration
    app.config.from_object(Config)

    app.wsgi_app = DebuggedApplication(app.wsgi_app, evalex=True)
    app.wsgi_app.trusted_hosts = {"localhost", "127.0.0.1", ".isucdc.com"}



    app.register_blueprint(routes.bp)

    return app
```

- Set all flask webapp “config.py” “SESSION_COOKIE_HTTPONLY” to true to prevent exfiltration of cookies using XSS.

```
import os

from flask import Flask
from werkzeug.debug import DebuggedApplication

from app import routes
from app.config import Config


def create_app():
    app = Flask(__name__)

    # Load configuration
    app.config.from_object(Config)

    app.wsgi_app = DebuggedApplication(app.wsgi_app, evalex=True)
    app.wsgi_app.trusted_hosts = {"localhost", "127.0.0.1", ".isucdc.com"}



    app.register_blueprint(routes.bp)

    return app
```

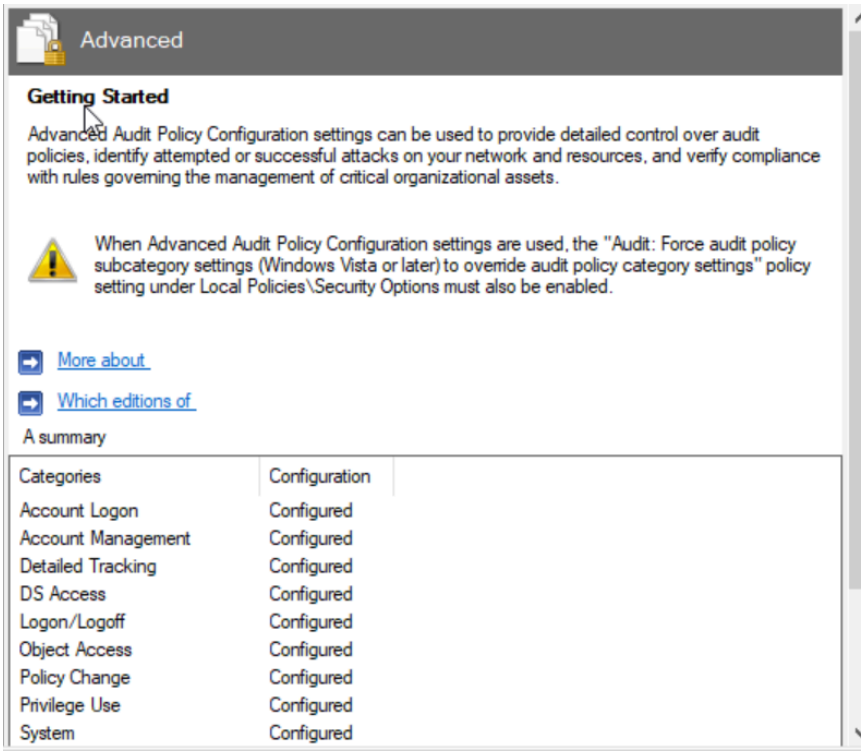
- Set Firewall Outbound to allow port 80 for http and 3389 for RDP

- Disabled Scrat and other unnecessary users



Name	Full Name	Description
Administrator		Built-in account for administering...
cdc	cdc	
DefaultAcco...		A user account managed by the s...
Guest		Built-in account for guest access t...
nsa		
scrat	scrat	1337 h4x0r
WDAGUtility...		A user account managed and use...

- Enabled audit policies and advanced audit policies for success & failures



Advanced

Getting Started

Advanced Audit Policy Configuration settings can be used to provide detailed control over audit policies, identify attempted or successful attacks on your network and resources, and verify compliance with rules governing the management of critical organizational assets.

When Advanced Audit Policy Configuration settings are used, the "Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings" policy setting under Local Policies\Security Options must also be enabled.

More about

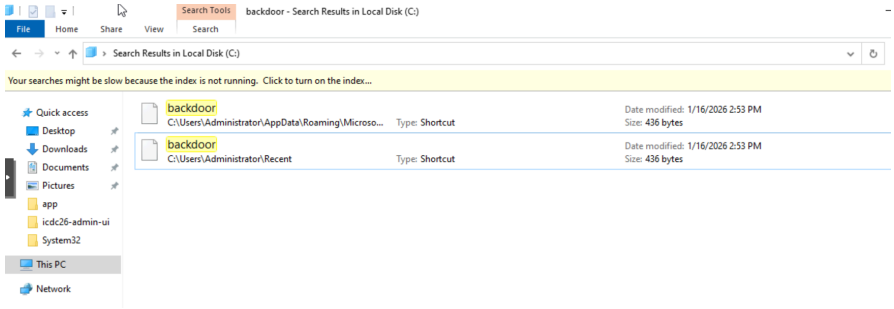
Which editions of

A summary

Categories	Configuration
Account Logon	Configured
Account Management	Configured
Detailed Tracking	Configured
DS Access	Configured
Logon/Logoff	Configured
Object Access	Configured
Policy Change	Configured
Privilege Use	Configured
System	Configured

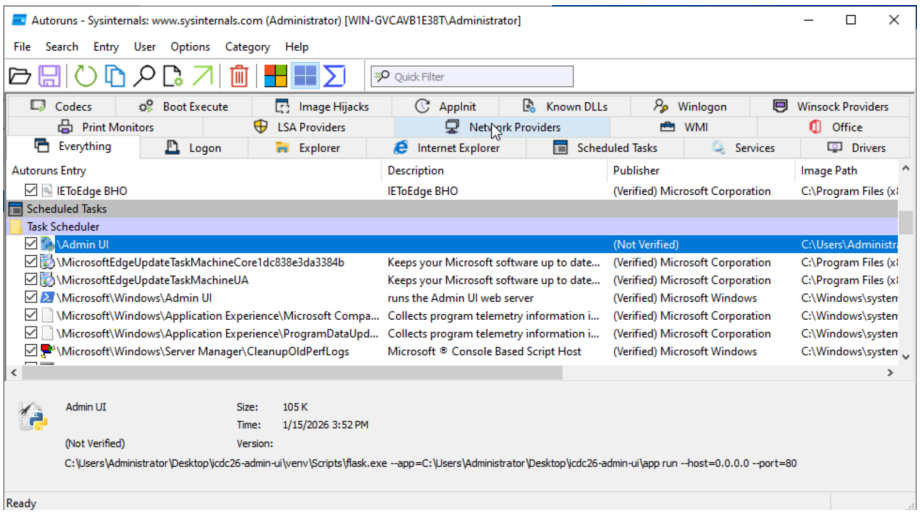
- Removed “backdoor.bat” and all shortcuts to it.

backdoor.bat	C:\Users\Administrator\Documents	2/1/2026 1:15 PM	1 KB	Windows Batch File	1/16/2026 3:57 PM



- Used Sysinternals to verify and correct flask via port 80

- Used Autoruns to ensure that the Admin UI Scheduled task was properly running on port 80.



Public Website (WWW)

This machine runs Alma Linux 9 and has a public ip of 76.5.61.50. This machine hosts the city's public website. Anybody can sign up and/or login, view bus and train routes, manage their account information, buy tickets, and scan their tickets on this website. The services hosted on this box are HTTP on port 80, and SSH on port 22.

Plan and Notes

As this is a public website we made sure to take in account many common website vulnerabilities that may present to the disclosure of users information.

Change Log

- The WWW machine has had its default user credentials rotated, as well as host based firewalls configured. It only allows connections from ports 22, 5000, 80, 443, 8080, and 53.

- WWW also had processes audited, and connections checked for malicious connections.

- We audited the source code of the flask application and found multiple misconfigurations listed below.

- The WWW machine has had cron removed and the following reinstalled: (openssh, pam, bash, core-utils). Conducted system hardening removing/auditing the following:

```
  ticket_mon.service        loaded active running "TicketServ-rs"
  tuned.service             loaded active running Dynamic System Tuning Daemon
  user@1000.service         loaded active running User Manager for UID 1000

LOAD   = Reflects whether the unit definition was properly loaded.
ACTIVE = The high-level unit activation state, i.e. generalization of SUB.
SUB    = The low-level unit activation state, values depend on unit type.
32 loaded units listed.
[root@www cdc]# systemctl status ticket_mon.service
● ticket_mon.service - "TicketServ-rs"
     Loaded: loaded (/etc/systemd/system/ticket_mon.service; enabled; preset: disabled)
     Active: active (running) since Tue 2026-02-10 17:41:10 EST; 1 day 18h ago
   Main PID: 946 (bash)
      Tasks: 7 (limit: 23073)
     Memory: 5.1M (peak: 5.3M)
        CPU: 59ms
     CGroup: /system.slice/ticket_mon.service
             ├─946 bash /usr/bin/ticketmon
             ├─948 nc -kl 0.0.0.0 12345
             ├─949 bash
             ├─950 nc -kl 0.0.0.0 12069
             ├─951 bash
             ├─952 nc -kl 0.0.0.0 1337
             └─953 bash

Feb 10 17:41:10 www.team11.isucdc.com systemd[1]: Started "TicketServ-rs".
```

  - Malicious users: clavis, pegasus, taco, stapunpriv
  - Backdoor script nsabackdoor.so which ran from LD_PRELOAD that fills the drive

```
[root@www cdc]# grep -r "LD_PRELOAD" /etc/
ERROR: ld.so: object '/usr/lib64/nsabackdoor.so' from LD_PRELOAD cannot be preloaded (cannot open shared object file): ignored.
/etc/profile.d/setup.sh:export LD_PRELOAD=/usr/lib64/nsabackdoor.so
/etc/sudo.conf:# support LD_PRELOAD or its equivalent.
[root@www cdc]#
```

- Edited weak password authorization in the code which allows for easy brute forcing

```
❯ rg -i "= \"cdc\""
mgmt/icdc26-backend-mgmt/app/config.py
9:     SECRET_KEY = "cdc"
20:     LDAP_PASS = "cdc"  # LDAP bind password

www/icdc2026frontend-main/app/config.py
9:     SECRET_KEY = "cdc"
```

- Login script did not check for passwords, which was remediated

```python
@bp.route("/login", methods=["POST"])
def login():
    data = request.get_json()
    username = data.get("username")
    password = data.get("password")

    if not username or not password:
        return jsonify({"error": "Username and password required"}), 400

    # success, is_admin = authenticate(username, password)
    success = ldap_exists(username)
    is_admin = True

    if not success:
        return jsonify({"error": "Authentication failed"}), 401

    session["username"] = username
    session["is_admin"] = is_admin

    return (
        jsonify({"message": "Login successful"}),
        200,
    )
```

discuss the operating system the box is running, what services are running on the box, the overall purpose of the box, our plan and methodology to set up and secure the box.

Backups

The back up box runs Ubuntu 24 with Rsync and Samba in order to manage backup data from most of our boxes.

Plan and Notes

Backups are being loaded onto a dedicated box at the specified address 10.2.0.3 on a 30 minute basis. Since we do not need constant access to this box, and this box is a high value target for attackers, we constricted access almost entirely and will only allow minimal connectivity if a backup is needed.

Router

The router is running pfSense version 2.7.2. The internal network is segmented into two networks, both managed by the router. The CADA subnet (10.1.0.0/24) contains the Admin UI Machine, Management Backend, and Ticketing Machine. This machine also hosts snort, an intrusion detection system (IDS).

Plan and Notes

Because the boxes/hosts serve specific operational roles, only traffic required for their functionality is allowed through the firewall. This provides an additional layer of security in addition to the local firewall for each system. This also allows the Snort service to monitor the network for any anomalies that we pre-defined. We set up alerts for repeated failed SSH and RDP attempts and common port scans (eg NMAP). This allows us to quickly and effectively find and block malicious IP addresses, protecting our services and network.

The Security LAN subnet (10.2.0.0/24) contains the backup system for our services. In the event that we are unable to recover from an attack, we can restore from a known good restore point. That being said, this is a big target for malicious actors. To prevent/minimize any compromises to the backup system, we have blocked all traffic from entering the network. If a situation arises where we need to access the machine, we will do so with minimal connectivity, ensuring the environment remains as isolated and uncompromised as possible.

We utilized network address translation (NAT) at the router level to make the process of segmenting our network easier. For example, if incoming traffic is going to

76.5.61.30:22, we can redirect it to 10.1.0.2:22. This ensures that any misconfigured firewall rules cannot be exploited. Below is an image containing most of our firewall rules.

Rules (Drag to Change Order)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
0/0 B	IPv4 *	199.100.16.101	*	76.5.61.249	*	*	none		Passed via EasyRule	
0/0 B	IPv4 ICMP echoreq	199.100.16.101	*	76.5.61.249	*	*	none		Passed via EasyRule	
0/0 B	IPv4 TCP	199.100.16.101	*	WAN address	*	*	none			
0/0 B	IPv4 UDP	*	*	76.5.61.10	53 (DNS)	*	none		NAT	
0/0 B	IPv4 TCP	*	*	10.1.0.4	3389 (MS RDP)	*	none		NAT AdminUI rdp	
0/0 B	IPv4 TCP	*	*	10.1.0.6	389 (LDAP)	*	none		AD LDAP	
0/0 B	IPv4 TCP	*	*	10.1.0.6	636 (LDAP/S)	*	none		AD LDAPS	
0/0 B	IPv4 TCP	*	*	10.1.0.2	5000	*	none		NAT Mgmt http	
0/0 B	IPv4 TCP	*	*	10.1.0.3	5000	*	none		NAT Tickets http	
0/0 B	IPv4 TCP	*	*	10.1.0.2	22 (SSH)	*	none		NAT Mgmt ssh	
0/0 B	IPv4 TCP	*	*	10.1.0.4	80 (HTTP)	*	none		NAT	
0/0 B	IPv4 TCP	*	*	10.1.0.3	3389 (MS RDP)	*	none		NAT Tickets rdp	
0/0 B	IPv4 TCP	76.5.61.10	*	*	*	*	none		dns	
0/0 B	IPv4 TCP	*	*	10.1.0.4	3389 (MS RDP)	*	none		AdminUI rdp	
0/0 B	IPv4 TCP	*	*	10.1.0.4	80 (HTTP)	*	none		AdminUI http	
0/0 B	IPv4 TCP	*	*	10.1.0.5	22 (SSH)	*	none		WWW SSH	
0/0 B	IPv4 TCP	*	*	10.1.0.5	80 (HTTP)	*	none		WWW	
0/0 B	IPv4 TCP	*	*	10.1.0.3	5000	*	none		Tickets http	
0/0 B	IPv4 TCP	*	*	10.1.0.3	3389 (MS RDP)	*	none		Tickets	
0/0 B	IPv4 TCP	*	*	10.1.0.5	3389 (MS RDP)	*	none		NAT WWW SSH	
0/0 B	IPv4 TCP	*	*	10.1.0.2	5000	*	none		NAT Mgmt http	
0/0 B	IPv4 TCP	*	*	10.1.0.5	80 (HTTP)	*	none		NAT	
0/0 B	IPv4 TCP/UDP	*	*	LAN address	1 - 65535	*	none		NAT AD LDAP	
0/0 B	IPv4 TCP	*	*	10.1.0.6	3389 (MS RDP)	*	none		NAT AD RDP	
0/0 B	IPv4 TCP	*	*	10.1.0.6	389 (LDAP)	*	none		NAT AD LDAP	
0/0 B	IPv4 TCP	*	*	10.1.0.6	636 (LDAP/S)	*	none		NAT AD LDAP	

To ensure that all services are accessible, we added rules for the specific IP addresses and ports that each machine requires.